

TASK1 SNEHA JATIYA

Cybersecurity is fundamentally about protecting information systems, and the CIA triad—**Confidentiality, Integrity, and Availability**—is its backbone. In banking and social media, these principles ensure trust, accuracy, and accessibility of data.

Cybersecurity is about **keeping data secret, accurate, and accessible**. The CIA triad provides a simple but powerful framework: protect confidentiality with encryption and access controls, maintain integrity with validation and monitoring, and ensure availability with redundancy and resilience. Whether it's a **banking app safeguarding money** or a **social media platform protecting conversations**, the triad ensures trust in digital systems.



CIA Triad

Principle	Meaning	Real-World Example
Confidentiality	Ensuring sensitive data is accessible only to authorized users.	Banking apps encrypt transactions so outsiders cannot see account details. Social media platforms use privacy settings to restrict who can view posts.
Integrity	Guaranteeing data remains accurate and unaltered unless authorized.	Banks prevent unauthorized changes to balances. Social media ensures posts aren't tampered with during transmission.
Availability	Systems and data must be accessible when needed.	Banks keep ATMs and online portals running even during cyberattacks. Social media platforms maintain uptime so users can post and interact.

- **Banking:** If confidentiality fails, customer financial data leaks. If integrity fails, balances could be manipulated. If availability fails, customers can't withdraw or transfer money.
- **Social Media:** Breaches of confidentiality expose private messages. Integrity failures could spread misinformation if posts are altered. Availability failures prevent users from accessing platforms, disrupting communication.



Risks When CIA Triad Breaks

- **Confidentiality breach** → Unauthorized access (e.g., hackers stealing credit card details).
- **Integrity breach** → Data manipulation (e.g., fake transactions or altered posts).
- **Availability breach** → Denial-of-service attacks making apps or websites inaccessible.

TASK1 SNEHA JATIYA

Cyber attackers can be grouped into categories based on their skills, motivations, and resources. The main types include script kiddies, insiders, hacktivists, and nation-state actors. Each poses unique risks to organizations.

Types of Attackers

Attacker Type	Characteristics	Example Attack	Motivation
Script Kiddies	Amateur hackers using pre-made tools/scripts without deep knowledge.	Website defacement, DDoS attacks.	Fun, curiosity, attention, revenge.
Insiders	Employees or contractors misusing legitimate access.	Stealing customer data, sabotaging systems.	Personal gain, revenge, negligence.
Hactivists	Ideology-driven attackers targeting organizations to promote causes.	Defacing government websites, leaking sensitive documents.	Political, social, or environmental activism.
Nation-State Actors	Highly skilled, well-funded groups backed by governments.	Espionage, targeting critical infrastructure, cyber warfare.	Strategic advantage, intelligence gathering, disruption.

Common Attack Surfaces

1. Web Applications

- **Risks:** SQL injection, Cross-Site Scripting (XSS), Broken Authentication.
- **Example:** An attacker injects malicious SQL into a banking login form to steal account details.
- **Why vulnerable:** User inputs often interact directly with backend databases.

2. Mobile Applications

- **Risks:** Insecure data storage, weak authentication, reverse engineering.
- **Example:** A malicious app steals WhatsApp chat backups stored insecurely on a device.

TASK1 SNEHA JATIYA

- **Why vulnerable:** Mobile apps often store sensitive data locally and rely on APIs.

3. APIs (Application Programming Interfaces)

- **Risks:** Broken access control, data exposure, endpoint abuse.
- **Example:** Attackers exploit a social media API to scrape private user data.
- **Why vulnerable:** APIs are designed for data exchange, making them attractive targets.

4. Networks

- **Risks:** Man-in-the-Middle (MITM), Denial of Service (DoS), packet sniffing.
- **Example:** Hackers intercept traffic on public Wi-Fi to steal banking credentials.
- **Why vulnerable:** Data travels across multiple nodes, often unencrypted.

5. Cloud Infrastructure

- **Risks:** Misconfigured storage buckets, exposed credentials, insecure multi-tenancy.
- **Example:** Sensitive files left in a misconfigured AWS S3 bucket accessible to the public.
- **Why vulnerable:** Shared resources and complex configurations increase attack opportunities.

Key Differences

Term	Meaning	Example	Why It Matters
Vulnerability	A flaw or weakness in software, hardware, or processes.	Using outdated banking app software with weak encryption.	Creates an opening for attackers.
Threat	A potential event or actor that could exploit a vulnerability.	A hacker attempting to steal login credentials.	Represents the “danger” that targets the weakness.
Risk	The likelihood and impact of a threat exploiting a vulnerability.	If the hacker succeeds, customer financial data is stolen, leading to fraud.	Helps organizations prioritize defenses.

TASK1 SNEHA JATIYA

OWASP Top 10 (2025) Vulnerabilities

The OWASP Top 10 (2025) is a global standard list of the most critical web application security risks. Each vulnerability represents a common way attackers exploit systems, and understanding them helps developers build safer applications

Code	Vulnerability	Why It's Dangerous	Example
A01:2025 – Broken Access Control	Users gain privileges they shouldn't have.	Leads to unauthorized data exposure or admin-level actions.	A normal user accessing another customer's bank account.
A02:2025 – Security Misconfiguration	Default settings, exposed admin panels, or missing patches.	Attackers exploit weak configurations easily.	Leaving default "admin/admin" credentials active.
A03:2025 – Software Supply Chain Failures	Compromised third-party libraries or dependencies.	Attack spreads through trusted software updates.	Malicious code hidden in a popular npm package.
A04:2025 – Cryptographic Failures	Weak or improper encryption.	Sensitive data like passwords or credit cards can be stolen.	Storing passwords in plain text.
A05:2025 – Injection	Malicious input alters queries or commands.	Attackers can steal or manipulate data.	SQL injection in login forms.
A06:2025 – Insecure Design	Flaws in architecture or logic.	Security gaps exist even before coding.	Banking app allowing unlimited failed login attempts.
A07:2025 – Authentication Failures	Weak login systems or poor session handling.	Attackers impersonate users.	No multi-factor authentication on sensitive accounts.
A08:2025 – Software & Data Integrity Failures	Updates or data can be tampered with.	Leads to malware injection or corrupted data.	Compromised update server distributing malicious patches.
A09:2025 – Vulnerable & Outdated Components	Using old libraries or frameworks.	Known exploits can be reused by attackers.	Running outdated WordPress plugins.
A10:2025 – Mishandling of Exceptional Conditions	Poor error handling leaks sensitive info.	Attackers learn system details to plan attacks.	Error messages revealing database structure.

Map daily-used applications

(Email, WhatsApp, Banking apps) to their **attack surfaces** so you can clearly see where attackers might strike.

Email

Attack Surfaces:

- **Web Application** → Phishing links, malicious attachments.
- **Network** → Man-in-the-Middle attacks on SMTP/IMAP traffic.
- **Cloud Infrastructure** → Misconfigured mail servers, exposed credentials.
- **APIs** → Email integration APIs abused for spam or data leaks.

Example: A phishing email tricks a user into entering banking credentials on a fake site.

WhatsApp

Attack Surfaces:

- **Mobile Application** → Insecure local storage of chat backups, reverse engineering of APKs.
- **APIs** → Exploitation of WhatsApp Business API for spam or scraping.
- **Network** → Metadata leaks if traffic isn't properly encrypted.
- **Cloud Infrastructure** → Backup files stored in Google Drive/iCloud exposed due to misconfiguration.

Example: Attackers intercept unencrypted metadata to track user communication patterns.

Banking Apps

Attack Surfaces:

- **Web Application** → SQL injection in login forms, session hijacking.
- **Mobile Application** → Weak authentication, insecure storage of PINs.
- **APIs** → Exploited to transfer funds or access account details.
- **Network** → MITM attacks on public Wi-Fi during transactions.
- **Cloud Infrastructure** → Misconfigured servers exposing customer financial data.

Example: An attacker exploits API flaws to initiate unauthorized fund transfers.

TASK1 SNEHA JATIYA



Data Flow: User → Application → Server → Database

1. User Layer

- User enters data (login credentials, messages, transactions).
- Example: You type your banking username/password or send a WhatsApp message.

2. Application Layer (Frontend)

- The app (web/mobile) collects input and sends it to the server.
- Example: Banking app login screen or WhatsApp chat interface.

3. Server Layer (Backend)

- Server processes requests, applies business logic, and communicates with the database.
- Example: Bank server checks if your credentials are valid.

4. Database Layer

- Database stores/retrieves user data (balances, messages, emails).
- Example: Bank database fetches your account balance.



Attack Points in the Flow

Layer	Possible Attacks	Example
User Layer	Phishing, credential theft, social engineering.	Fake banking login page steals your password.
Application Layer	Injection (SQL/XSS), insecure design, broken authentication.	Malicious input alters queries to access another user's data.
Server Layer	Misconfiguration, privilege escalation, denial of service.	Exposed admin panel lets attacker control the server.
Database Layer	SQL injection, data exfiltration, ransomware.	Attacker dumps entire customer database.
Network Layer (between all)	Man-in-the-Middle, packet sniffing, DDoS.	Hacker intercepts WhatsApp traffic on public Wi-Fi.

TASK1 SNEHA JATIYA



Final Summary in My Words

Cybersecurity is about **protecting the flow of data** as it travels from the **user** → **application** → **server** → **database**. At each stage, attackers have opportunities:

- **Users** can be tricked (phishing).
- **Applications** can be exploited (injection, broken authentication).
- **Servers** can be misconfigured or overloaded.
- **Databases** can be targeted for theft or corruption.
- **Networks** can be intercepted (MITM, DDoS).

By mapping these flows, we see that **every step is a potential attack surface**. Defenses must therefore be **layered**—encrypting data, validating inputs, patching systems, and monitoring traffic. This holistic view ensures that whether it's a **banking app, WhatsApp, or email**, the CIA triad (Confidentiality, Integrity, Availability) remains intact.
